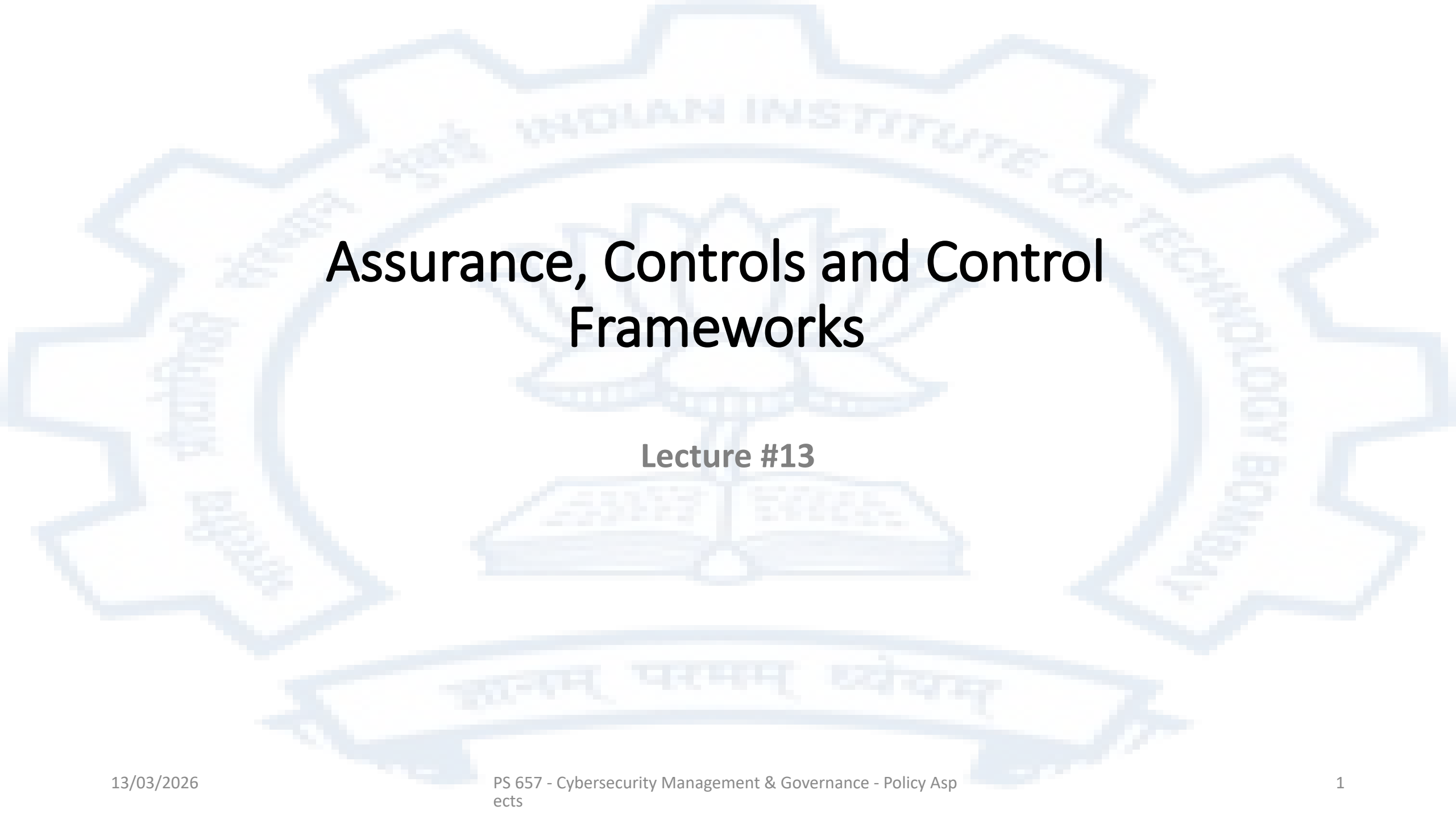




Assurance, Controls and Control Frameworks

Lecture #13

Assurance

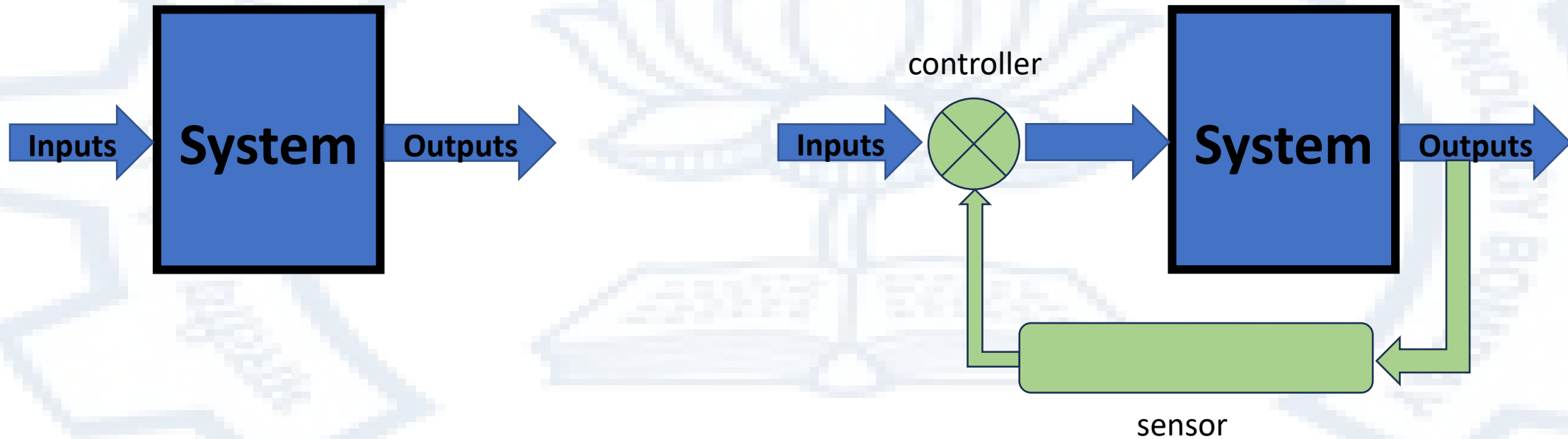
a statement that something will certainly be true or will certainly happen, particularly when there has been doubt about it

- Oxford Dictionary

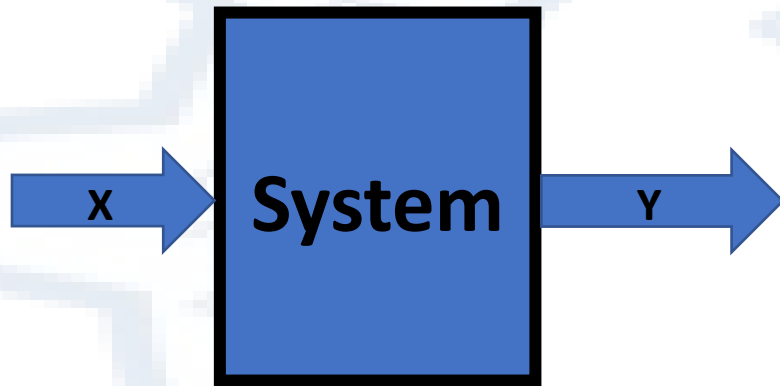
Mechanisms to back Assurance

- Technical and/or managerial arrangements made to increase the likelihood that certain events will or will not occur
- Legal arrangements made to compensate or transfer liability should certain events occur/not occur
- These mechanisms are called controls (the second definition)
 1. *to have power and ability to make somebody/something do what you want*
 2. *to keep something within certain limits*

Simple control systems – a simple closed loop feedback control system



A Simple feedback control strategy



$$Y=F(X)$$

If there is a small change in Y how much should X be changed to bring Y back to its original value?

- Proportional control $\Delta X = k \Delta Y$
- There can be more complex methods of computing ΔX

Controls

- Control Objective
 - The control objective is the “why and what” of assurance that is sought to be assured by the control
- Control Implementation (design and operation)
 - The control implementation is the “how”
 - This involves specific technological mechanisms and/or processes which are designed to achieve the control objectives

Technical Controls

Technical controls are physical or logical mechanisms whose operation will result in the control objectives being met

Examples

- The control objective is to prevent unauthorized disclosure of information
 - A possible technical control is to use encryption to protect the data
- The control objective is to prevent proxy-attendance
 - A possible technical control is to use biometric attendance systems
- The control objective is to prevent equipment damage due to high current
 - A possible technical control is to use a fuse

Managerial/Procedural Controls

A managerial or procedural control is a set of processes which, when followed, will result in the control objectives being met

Examples

- The control objective is to prevent unsuitable people from joining and organization
 - A possible managerial control is carrying out interviews
- The control objective is to ensure that a student has the right background before enrolling for a course
 - A possible managerial control is to prescribe a set of pre-requisites and only permit those that satisfy the pre-requisites to enroll for the course
- The control objective is to ensure that a project is executed on time
 - A possible managerial control is to have a project plan and assign a manager to ensure that the plan is followed

Controls in Engineering

- Procedural controls
 - Design codes
 - Safety codes
- Technical controls
 - Control systems engineering

Controls in healthcare

- Procedural
 - Treatment protocols
 - Quarantine procedures
- Technical
 - Heart Lung machines
 - Dialysis machines
 - Administration of drugs

Controls in Finance

- **An example for financial controls in the area of cash flows is**
 - Stringent credit reporting policy for all customers before entering into a creditor-debtor relationship with them
 - Periodic reconciliation of bank statements to the general ledger in addition to annual reporting for more efficient financial control
 - Establishing a periodic review policy with all existing customers that the business establishes a creditor-debtor relationship with. It ensures the ongoing creditworthiness of customers and eliminates the probability of bad debts
 - Support files and backups for all financial data in a separate secured database with access only permitted to senior management staff
 - Automatic/subscription payments to be monitored and requiring proper authorization in order to control extravagant business expenditure
 - Maintaining a vendor database with detailed purchase records with restricted access in order to monitor cash outflow efficiently
 - Periodic reconciliation of bank statements to the general ledger
 - Clear and precise expense reimbursement policy to be maintained, including detailed expense reports and receipt verifications in order to curb extravagant business expenses and employee fraud

Control Frameworks

An internal control framework is a structured guide that organizes and categorizes expected controls or control topics. Some organizations design control frameworks for general purposes like the COSO internal control framework, while others are more specific such as the COBIT IT Control framework. When an organization uses a control framework effectively (typically in audit risk assessments and risk management), management designs internal control processes with the framework as a baseline. Doing so helps the organization design control procedures that create and preserve value while minimizing risk.

<https://www.auditboard.com/blog/auditing-control-frameworks-COBIT-COSO-ISO/>

Some Examples of Control Frameworks

The “control” terminology has been largely used in the financial domain but the concept of controls exists in almost every domain. Some examples of control frameworks are

- COSO
 - Generic management and financial controls
- COBIT
 - IT controls
- ISO 9001
 - Quality controls
- ISO 27001
 - Information security controls

The COSO cube for internal control



<https://accountinginternalcontrols.com/coso-framework/>

COSO – Objectives for internal control

- Operations objectives refer to the entity's business processes, goals, and protection of assets.
- Reporting objectives refer to the reliability of both external and internal financial and non-financial reporting.
- Compliance objectives refer to the laws and regulations that the entity is subject to.

COSO – Organizational structure of internal control

- Entity level refers to the whole company
- Division refers to business segments separated by product or service lines
- Operating Unit refers to a specific group within that division
- Function refers to a specific job in the operating unit

COSO – Components of internal control

- Control Environment sets the tone at the top and company policies.
- Risk Assessment identifies areas that expose the company to higher risks both internally and externally.
- Control Activities are the policies and procedures that a company implements.
- Information and Communication are utilized from internal and external sources to stay up on internal and external changes.
- Monitoring is the evaluation that processes, policies, and procedures are occurring as expected.

COBIT – Control Objectives for Information and related Technologies

COBIT is a framework for the governance and management of enterprise information and technology, aimed at the whole enterprise. COBIT defines the components and design factors to build and sustain a best-fit governance system.

KEY CONCEPTS

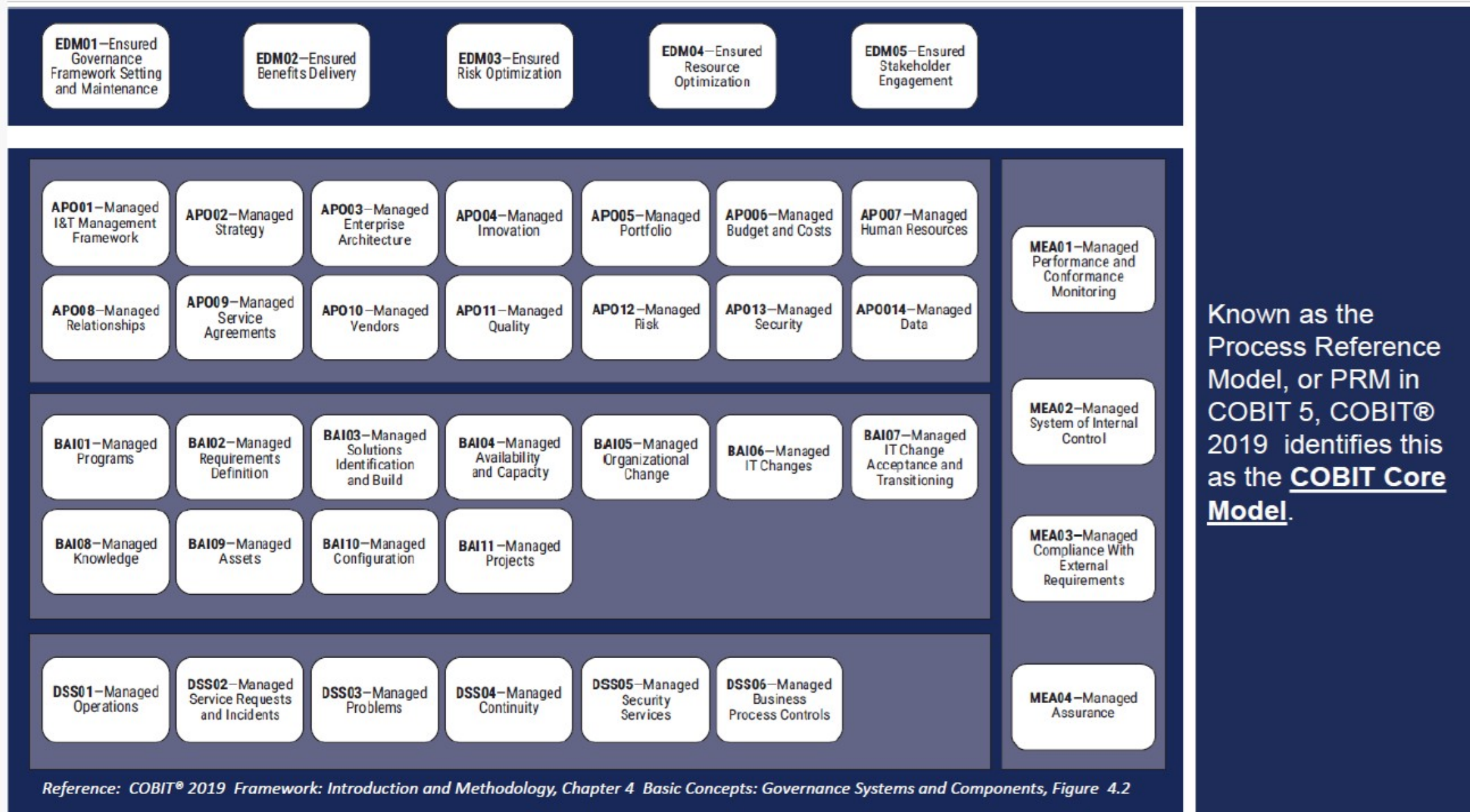
GOVERNANCE AND MANAGEMENT OBJECTIVES

Similar to COBIT 5, The governance and management objectives in COBIT® 2019 are grouped into five domains. The domains have names that express the key purpose and areas of activity of the objectives contained in them.



© 2018 ISACA. All rights reserved.

COBIT2019



Known as the Process Reference Model, or PRM in COBIT 5, COBIT® 2019 identifies this as the **COBIT Core Model**.

The ISO 27001 framework for Cybersecurity

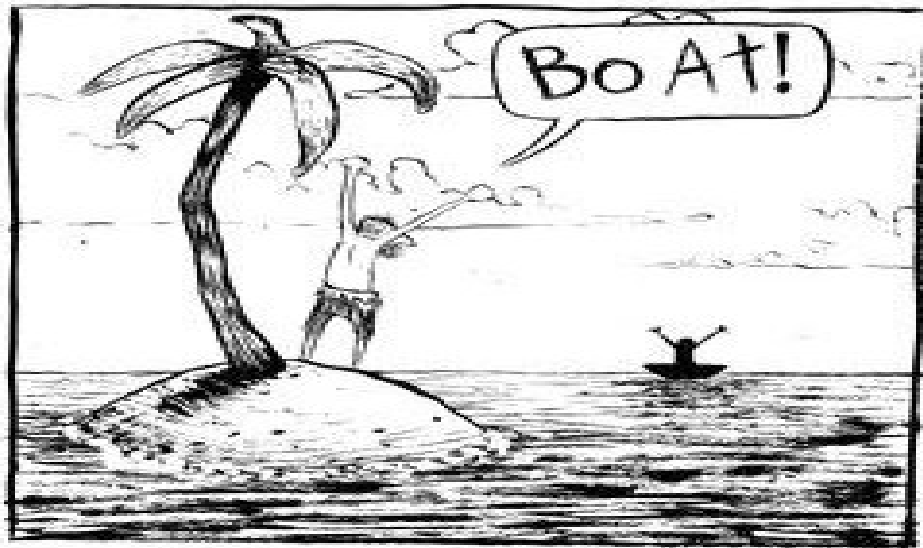
- ISO 27001 defines the following security domains (control categories)

Information security policies	Organisation of information security
Human resource security	Asset management
Access control	Cryptography
Physical and environmental security	Operations security
Operations security	System acquisition, development and maintenance
Supplier relationships	Information security incident management
Information security aspects of business continuity management	Compliance

Possible Issues with Controls

- Absent Controls
- Ineffective Controls
 - Inadequate design
 - Inadequate operation
- Audit
 - An assessment, often by an independent party, of whether the controls are operating as specified
 - This is usually the final level of assurance
 - The assumption is audits will be impartial and carried out with integrity. All too often these assumptions have been found to be mistaken

Your perspective depends on where you stand



Typical Cybersecurity Concerns for Individuals

- Monetary losses
- Loss of valuable data
- Health impacts
- Privacy loss

Citizens

- Rely upon
 - Device manufacturers to keep their mobile devices safe
 - The Apple ecosystem
 - The Android/Google ecosystem
 - Some basic antivirus software for desktops and laptops
 - Security features provided by product/service vendors
 - (Some {very few}) Users follow good cyber-hygiene
- Expect
 - Government to provide suitable cybersecurity safeguards by way of laws and regulations
 - Product/Service providers to deliver secure products/services

Typical Cybersecurity Concerns of Governments

- Security of their national critical infrastructure
- Industrial espionage aimed at their important industries
- Use of cyber-channels to carry out activity inimical to national security and/or public order
 - Espionage
 - Subversion
- Influence operations where targets are not IT or other connected infrastructure but human minds
 - Narratives
 - Fake news

Governments

- Enact laws and promulgate policies and regulations that
 - Provide for civil and criminal penalties for certain kinds of behaviour
 - Place obligations and compliance requirements on citizens and organizations
- Engage in and catalyze capacity building
 - Defensive capabilities
 - Offensive capabilities
 - Awareness programmes
- Create infrastructural ecosystems that are intended as foundational building blocks
- Need to ensure that their own organizations adopt acceptable cybersecurity postures

Typical Cybersecurity Concerns of Enterprises

- Reputation and consequent business loss arising from inability to protect their IT systems
- Reputation and consequent business loss arising from failure to deliver secure services/services securely
- Loss of competitive advantage
 - IPR loss
 - Reputation loss
- Regulatory fines and penalties
- The inherent cross-border nature of the Internet and consequently of cybersecurity causes jurisdictional conflicts and raises the compliance burden and creates ambiguity

Enterprises

- Need to systematically manage their cybersecurity obligations, demonstrate compliance with those obligations and manage the risks associated with failures
- Usually implement some sort of Cyber(Information) Security Management System
 - The most commonly implemented management system is based on the ISO 27000 family of standards
- Are faced with procuring/implementing/operating a very diverse and somewhat large array of security tools and systems creating a need for hyperspecialized skills

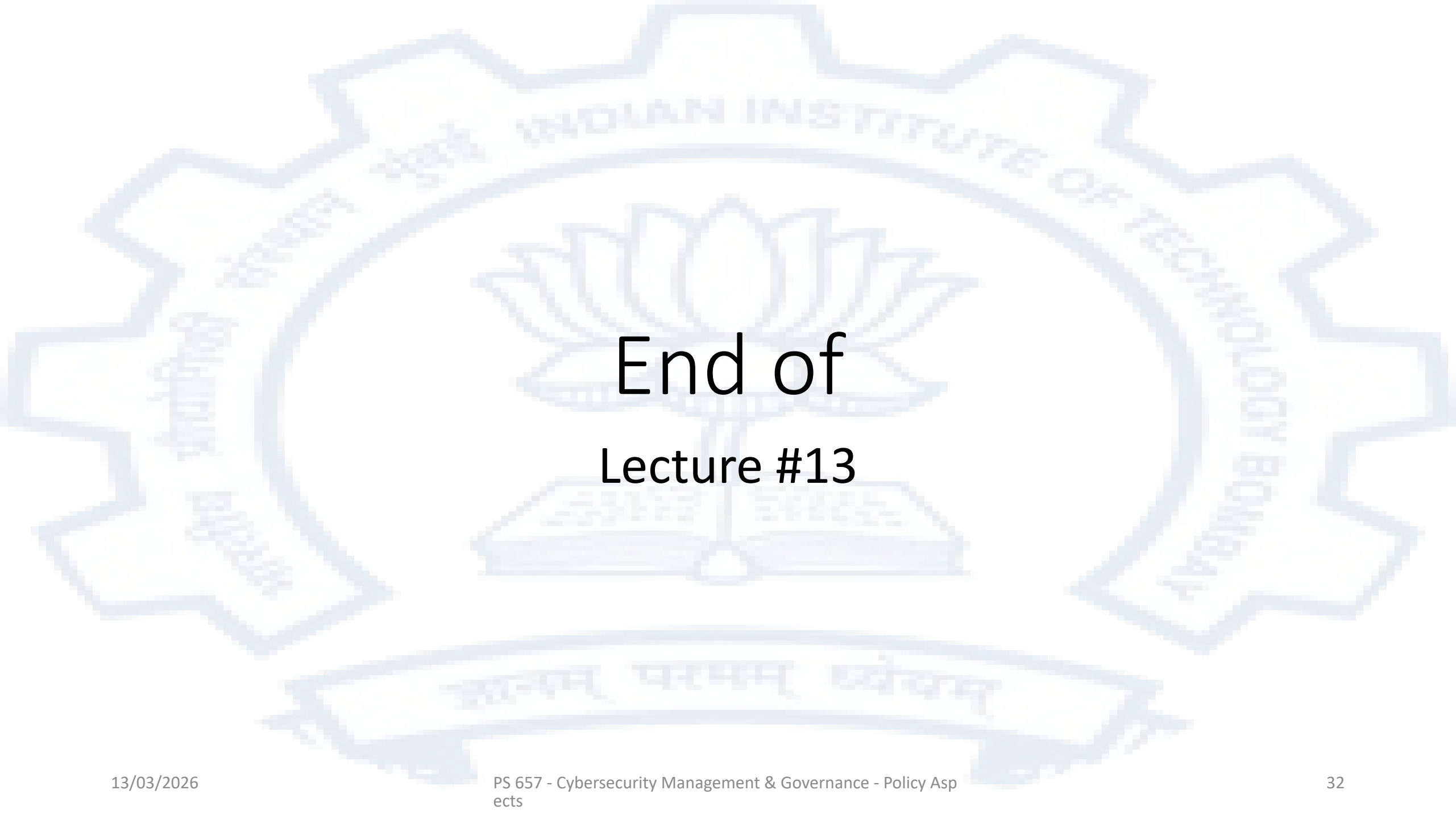
Other forms of Assurance

In case controls fail and unintended consequence ensue, there are mechanisms of redressal. Examples are

- Warranties
- Explicit liquidated damages for
 - Direct harm
 - Consequential harm
- Legal liabilities

Summary

- Expectations need to be backed by assurances
- Assurances can be thought of as controls
- Controls can be
 - Technical
 - Managerial/procedural
- Controls are assured by audit
- Audit is often found wanting
- Contractual/legal mechanisms are used in case controls fail and unintended consequence ensue



End of Lecture #13